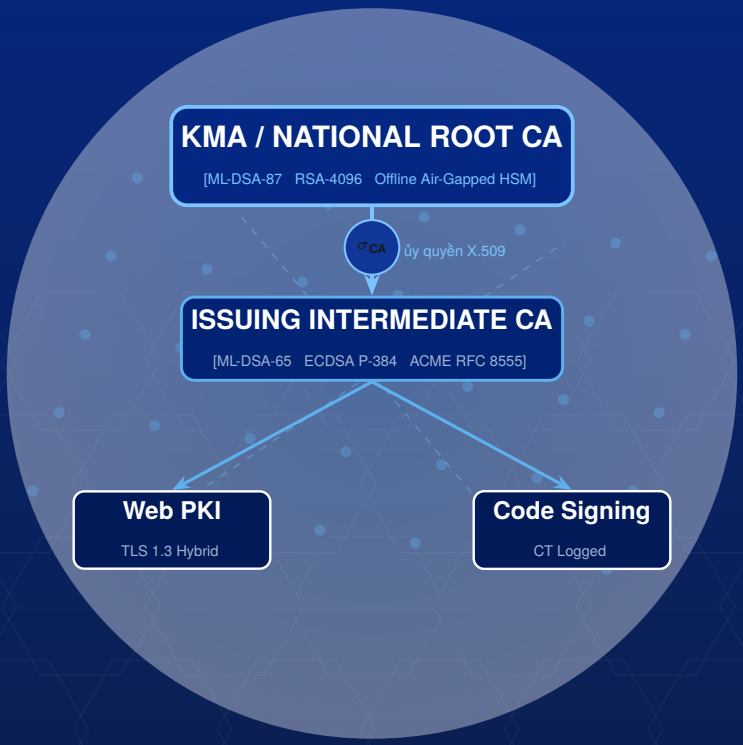


$g^{ab} \pmod{p}$
Trapdoor DLP

RFC 5280
X.509 v3 ASN.1

RFC 6962
CT Merkle Logs

FIPS 204
ML-KEM / ML-DSA

Cơ sở Hạ tầng Khóa công khai

& Chuyển dịch Mật mã Hậu lượng tử (PQC)

Tài liệu học tập học phần ATHK 512

Chủ biên:

Nguyễn An Khương [ORCID: 0000-0002-9910-6387]

Trợ giảng học phần:

Nguyễn Hữu Hoàng Huy

Trường Đại học Bách khoa — ĐHQG-HCM

Khoa Khoa học và Kỹ thuật Máy tính

CƠ SỞ HẠ TẦNG KHÓA CÔNG KHAI

VÀ CHUYỂN DỊCH MẬT MÃ HẬU LƯỢNG TỬ (PQC)

TÀI LIỆU HỌC TẬP HỌC PHẦN ATHK 512

Khóa đào tạo: Cao học An toàn Thông tin (CHAT4P) · HK261

Nguyễn An Khương

Khoa Khoa học và Kỹ thuật Máy tính, Trường Đại học Bách khoa — ĐHQG-HCM

Mã định danh học thuật toàn cầu: ORCID: 0000-0002-9910-6387

Email: nakhuong@hcmut.edu.vn · nakhuong@gmail.com

Trợ giảng: Nguyễn Hữu Hoàng Huy

Hồ sơ chuyên môn: LinkedIn Profile · GitHub: @HuyLHP

Thành phố Hồ Chí Minh — Năm học 2026–2027

Bản quyền & Giấy phép phát hành:
© 2026 Nguyễn An Khương. Tác phẩm này được phát hành dưới Giấy phép Quốc tế Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 (CC BY-NC-ND 4.0). Người học được phép sao chép và chia sẻ cho mục đích học tập cá nhân phi thương mại. Toàn bộ mã nguồn thực nghiệm và script đi kèm phát hành theo Giấy phép Nguồn mở MIT.
Nhận diện thương hiệu: Bộ nhận diện thương hiệu Trường Đại học Bách khoa — ĐHQG-HCM (04/2021). Font: TeX Gyre Schola / Source Sans 3.

Lời nói đầu

Hạ tầng Khóa Công khai (Public Key Infrastructure – PKI) từ lâu đã trở thành ”xương sống vô hình” bảo đảm tính bảo mật, toàn vẹn, xác thực và chống chối bỏ cho toàn bộ thế giới số hiện đại. Từ giao thức bắt tay TLS bảo vệ hàng tỷ phiên duyệt web an toàn mỗi ngày, chữ ký số trên các chứng từ tài chính – ngân hàng, đến các định danh thiết bị IoT và cơ chế khởi động an toàn (Secure Boot) trong hệ điều hành máy tính — tất cả đều vận hành dựa trên các nguyên lý cốt lõi của PKI.

Tuy nhiên, kỷ nguyên số đang bước vào một khúc quanh lịch sử với hai chuyển biến mang tính cách mạng:

1. **Kiến trúc Zero Trust & Điện toán Đám mây Phân tán:** Mô hình chu vi mạng truyền thống bị xóa bỏ hoàn toàn. Các hệ thống hiện đại đòi hỏi hàng triệu kết nối mTLS giữa các microservices được mã hóa với chứng chỉ có thời hạn sống biểu kiến (ephemeral certificates tính bằng giờ hoặc phút), kéo theo yêu cầu tự động hóa tuyệt đối thông qua giao thức ACME (RFC 8555) và kiểm định tuân thủ tự động (ZLint).
2. **Nguy cơ Hiện hữu từ Điện toán Lượng tử (Post-Quantum Transition):** Thuật toán lượng tử Shor đã chứng minh khả năng bẻ gãy hoàn toàn các hệ mật mã khóa công khai kinh điển dựa trên bài toán phân tích thừa số nguyên tố (RSA) và logarit rời rạc (DSA, ECDSA, ECDH) trong thời gian đa thức. Tháng 8/2024, Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ (NIST) đã chính thức ban hành bộ tiêu chuẩn FIPS 203 (ML-KEM), FIPS 204 (ML-DSA) và FIPS 205 (SLH-DSA), mở ra một cuộc đại di chuyển mật mã (cryptographic migration) quy mô toàn cầu chưa từng có trong lịch sử nhân loại.

Bộ **Tài liệu học tập: Cơ sở Hạ tầng Khóa công khai & Mật mã Hậu lượng tử** này được biên soạn dành riêng cho học viên cao học ngành An toàn Thông tin (CHAT4P) nhằm trang bị một góc nhìn sâu sắc, toàn diện và hiện đại: kết hợp chặt chẽ giữa **nền tảng toán học hàn lâm chuẩn mực**, **chuẩn giao thức kỹ thuật quốc tế (IETF RFCs, CA/B Forum, NIST FIPS)** và **năng lực thực chiến công nghiệp (DevSecOps, Docker, OpenSSL 3.5, liboqs, HSM)**.

Tài liệu được kết cấu thành 8 chương chuyên sâu kèm theo hệ thống phụ lục thực nghiệm phong phú, đóng vai trò là kim chỉ nam xuyên suốt 9 buổi học lý thuyết, thực hành phòng lab và 5 đề tài đồ án chuyên đề lớn của học phần. Mọi chương đều tích hợp đầy đủ các thiết bị sư phạm hiện đại kế thừa chuẩn mực học thuật của ĐHBK: Bản đồ nhận thức, Ghi chú lịch sử, Nhìn vào bản chất, Cạm bẫy an ninh, Bài toán mở, Thực hành ngay và Gói tự kiểm tra.

Nguyễn An Khương

Khoa Khoa học và Kỹ thuật Máy tính
Trường Đại học Bách khoa — ĐHQG-HCM
Tháng 10 năm 2026

Mục lục

Lời nói đầu iii

1 Nền Tảng Lý Thuyết Số & Cơ Sở Toán Học Mật Mã Khóa Công Khai 1
- 1.1 Cấu Trúc Đại Số Trừu Tượng & Các Phép Toán Số Học 1
  - 1.1.1 Nhóm (Groups), Vành (Rings) và Trường Hữu Hạn (Finite Fields) . 1
  - 1.1.2 Các Định Lý Số Học Cốt Lõi 2
- 1.2 Hàm Một Chiều Có Cửa Sập & Bài Toán Khó 2
- 1.3 Hệ Mật RSA & Tối Ưu Hóa RSA-CRT 3
- 1.4 Mật Mã Đường Cong Elliptic (ECC) 3

2 Cấu Trúc Dữ Liệu Chứng Chỉ X.509 v3 & Quy Cách Mã Hóa ASN.1 DER 7
- 2.1 Cú Pháp ASN.1 & Quy Tắc Mã Hóa Nhị Phân DER 7
  - 2.1.1 Cấu Trúc Khung Nhị Phân TLV (Tag – Length – Value) 7
- 2.2 Cấu Trúc Khung Nhị Phân RFC 5280 8
- 2.3 Các Phần Mở Rộng Trọng Yếu (Critical Extensions) 8

3 Kiến Trúc Phân Tầng CA, Vòng Đời Khóa & Quy Chế CP/CPS (RFC 3647) 11
- 3.1 Kiến Trúc Chuỗi Tin Cậy Phân Tầng (3-Tier CA Hierarchy) 11
- 3.2 Khung Quy Chế CP và CPS Theo Chuẩn IETF RFC 3647 12
- 3.3 Nghi Thức Lễ Sinh Khóa (Key Ceremony) & Chuẩn HSM 12

4 Thuật Toán Xác Thực Đường Dẫn Tin Cậy & Cơ Chế Thu Hồi Chứng Chỉ 15
- 4.1 Thuật Toán Thẩm Định Đường Dẫn (Path Validation Algorithm) 15
- 4.2 Cơ Chế Thu Hồi Chứng Chỉ: CRL vs OCSP vs OCSP Stapling 16
- 4.3 Kỹ Thuật OCSP Stapling & Chuẩn OCSP Must-Staple (RFC 7633) 16

5 Giao Thức Quản Trị Tự Động ACME (RFC 8555) & Hạ Tầng Zero Trust PKI 19
- 5.1 Triết Lý Zero Trust & Thách Thức Quản Trị Chứng Chỉ Ngắn Hạn 19
- 5.2 Giao Thức Quản Trị Tự Động ACME (IETF RFC 8555) 19
  - 5.2.1 Vòng Đời Giao Thức ACME 19
  - 5.2.2 Các Phương Thức Thử Thách Sở Hữu Tên Miền 20
- 5.3 Kiến Trúc mTLS Service Mesh & Quản Trị Danh Tính Động 20

6 Các Kịch Bản Tấn Công Hạ Tầng PKI & Chiến Lược Phòng Thủ Toàn Diện **23**
6.1 Tổng Quan Mô Hình Đe Dọa Trên Hạ Tầng PKI 23
6.2 Các Bài Học Xương Máu Trong Lịch Sử PKI 23
6.2.1 Vụ Án DigiNotar (Hà Lan – 2011) 23
6.2.2 Vũ Khí Mạng Flame (2012) 24
6.3 Ma Trận Tấn Công Active Directory Certificate Services (AD CS) 24
6.4 Kiểm Định Tự Động Tuân Thủ Bằng ZLint 24

7 Chuyển Dịch Hệ Thống Sang Mật Mã Hậu Lượng Tử (PQC Migration) **27**
7.1 Mối Đe Dọa Của Điện Toán Lượng Tử & Thuật Toán Shor 27
7.2 Hiểm Họa Thu Hoạch Trước, Giải Mã Sau (HNDL) 27
7.3 Bộ Tiêu Chuẩn NIST PQC Chính Thức (Tháng 8/2024) 28
7.4 Thách Thức Kỹ Thuật: Phân Mảnh TCP MTU & Kiến Trúc Lai Hybrid . . 28

8 Khung Pháp Lý, Quy Chuẩn Kỹ Thuật & Hạ Tầng Chữ Ký Số Quốc Gia **31**
8.1 Hành Lang Pháp Lý: Luật Giao Dịch Điện Tử Năm 2023 31
8.2 Chiến Lược Quốc Gia Về Chuyển Dịch PQC Theo Quyết Định 1875/QĐ-TTg 31
8.3 Kiến Trúc Hạ Tầng Khóa Công Khai Quốc Gia 32
8.4 Công Nghệ Chữ Ký Số Từ Xa (Remote Signing / Cloud PKI) 32

Cẩm Nang 50 Lệnh OpenSSL 3.5 Thực Chiến **35**
.1 Quản Trị Khóa & Tham Số Mật Mã 35
.2 Yêu Cầu Ký Chứng Chỉ (CSR) & Cấu Hình SAN 35
.3 Ký Phát Hành & Thẩm Tra Chuỗi X.509 35
.4 Kiểm Tra Thu Hồi & Giao Thức OCSP 36

Bộ Công Cụ Python Cryptography Kiểm Định X.509 **37**

Danh Mục Tài Liệu Tham Khảo Hàn Lâm & Video OCW Quốc Tế **39**
.5 Tiêu Chuẩn Quốc Tế IETF RFC & CA/B Forum 39
.6 Tiêu Chuẩn Viện Tiêu Chuẩn & Công Nghệ Quốc Gia Hoa Kỳ (NIST) . . . 39
.7 Sách Chuyên Khảo Kinh Điển 39
.8 Khóa Học Mở Quốc Tế (OpenCourseWare – OCW) 40

1

Nền Tảng Lý Thuyết Số & Cơ Sở Toán Học Mật Mã Khóa Công Khai

Bạn đang ở đâu: Nền tảng đại số trừu tượng → Bài toán khó (Factorization, DLP, ECDLP) → Cơ chế Trapdoor → Bài toán mạo danh MitM → Định danh Identity Binding

1.1 Cấu Trúc Đại Số Trừu Tượng & Các Phép Toán Số Học

Mật mã khóa công khai không thể tồn tại nếu thiếu nền tảng vững chắc của đại số trừu tượng. Thay vì hoạt động trên tập số thực liên tục $\mathbb{R}$, mật mã học hiện đại vận hành trên các cấu trúc rời rạc hữu hạn nhằm bảo đảm tính chính xác tuyệt đối và ngăn chặn triệt để hiện tượng sai số làm tròn số học.

1.1.1 Nhóm (Groups), Vành (Rings) và Trường Hữu Hạn (Finite Fields)

Định nghĩa 1.1 *(Nhóm đại số).* Một tập hợp G cùng với phép toán hai ngôi $\star$ được gọi là một *nhóm* $(G, \star)$ nếu thỏa mãn 4 tiên đề:

1. **Tính đóng (Closure):** $\forall a, b \in G \implies a \star b \in G$.
2. **Tính kết hợp (Associativity):** $\forall a, b, c \in G \implies (a \star b) \star c = a \star (b \star c)$.
3. **Phần tử trung hòa (Identity):** $\exists e \in G, \forall a \in G \implies a \star e = e \star a = a$.
4. **Phần tử nghịch đảo (Inverse):** $\forall a \in G, \exists a^{-1} \in G \implies a \star a^{-1} = a^{-1} \star a = e$.

Nếu phép toán có tính giao hoán $a \star b = b \star a$, nhóm được gọi là *nhóm Abel*. □

Vành số dư $\mathbb{Z}_n = \{0, 1, \dots, n-1\}$ là vành cơ bản của hệ mật RSA. Trường hữu hạn Galois $\mathbb{F}_q$ chỉ tồn tại khi số phần tử $q = p^m$ (với p là số nguyên tố và $m \geq 1$):

- Khi $m = 1$, ta có trường số nguyên tố $\mathbb{F}_p = \mathbb{Z}_p$, nơi các phép toán modulo p diễn ra.
- Khi $m > 1$, ta có trường mở rộng $\mathbb{F}_{2^m}$, đặc biệt quan trọng trong các bộ đồng xử lý mật mã phần cứng.

1.1.2 Các Định Lý Số Học Cốt Lõi

Định lý 1.1 (Bổ đề Bézout & Nghịch đảo Modulo). *Với hai số nguyên a, b, luôn tồn tại hai số nguyên x, y sao cho:*

$$a \cdot x + b \cdot y = \gcd(a, b) \tag{1.1}$$

Khi $\gcd(a, n) = 1$, ta có $a \cdot x \equiv 1 \pmod{n}$, tức $x = a^{-1} \pmod{n}$. Thuật toán Euclid mở rộng tính toán phần tử nghịch đảo này trong thời gian đa thức cực nhanh $\mathcal{O}(\log n)$. □

Định lý 1.2 (Định lý Euler & Định lý Fermat nhỏ). *Với số nguyên dương n, hàm phi Euler $\phi(n)$ đếm số lượng các số nguyên dương nhỏ hơn n và nguyên tố cùng nhau với n. Nếu $n = p \cdot q$ (p, q nguyên tố), thì $\phi(n) = (p-1)(q-1)$. Khi đó, với mọi a nguyên tố cùng nhau với n:*

$$a^{\phi(n)} \equiv 1 \pmod{n} \tag{1.2}$$

Trường hợp đặc biệt khi $n = p$ là số nguyên tố, ta thu được Định lý Fermat nhỏ: $a^{p-1} \equiv 1 \pmod{p}$. □

> **Ghi chú lịch sử**
>
> Năm 1976, hai nhà nghiên cứu tại Đại học Stanford là Whitfield Diffie và Martin Hellman đã công bố bài báo lịch sử *"New Directions in Cryptography"* (kế thừa các ý tưởng Merkle Puzzles của Ralph Merkle). Công trình này đã phá vỡ thế độc tôn hàng nghìn năm của mật mã đối xứng, đặt nền móng cho cuộc cách mạng mật mã khóa công khai. Chỉ một năm sau đó (1977), Ron Rivest, Adi Shamir và Leonard Adleman tại MIT đã hiện thực hóa khái niệm này bằng thuật toán RSA lừng danh.

1.2 Hàm Một Chiều Có Cửa Sập & Bài Toán Khó

Mọi hệ thống mật mã khóa công khai đều được xây dựng trên nền tảng của **Hàm một chiều có cửa sập (Trapdoor One-Way Function – TOWF)**:

$$f : X \to Y \tag{1.3}$$

Hàm f phải thỏa mãn ba đặc trưng toán học nghiêm ngặt:

1. **Dễ tính toán theo chiều xuôi:** Cho trước $x \in X$, việc tính $y = f(x)$ là một bài toán thời gian đa thức $\mathcal{O}(\text{poly}(|x|))$.
2. **Bất khả thi theo chiều ngược (Hard to Invert):** Cho trước $y \in Y$, việc tìm x sao cho $f(x) = y$ là bài toán bất khả thi về mặt độ phức tạp tính toán đối với bất kỳ thuật toán cổ điển nào.
3. **Cửa sập bí mật (Trapdoor Key):** Tồn tại một thông tin bổ trợ đặc biệt K_{priv}. Khi biết K_{priv}, việc tính ngược $x = f^{-1}(y, K_{\text{priv}})$ trở thành một bài toán đa thức tường minh và hiệu quả.

> **Nhìn vào bản chất**
>
> Toán học mật mã thuần túy rất mạnh mẽ, nhưng **nó không thể tự giải quyết được bài toán lòng tin**. Kẻ tấn công đứng giữa kênh truyền (Mallory) hoàn toàn có thể thay thế khóa công khai của Alice bằng khóa của chính hắn mà Bob không có cách nào phát

hiện nếu chỉ dựa vào số học. Để giải quyết nguy cơ này, năm 1978, chàng sinh viên cử nhân Loren Kohnfelder tại MIT đã đề xuất khái niệm *"Digital Certificate"* (chứng chỉ số) — gắn chặt khóa công khai với định danh pháp lý thông qua chữ ký của bên thứ ba đáng tin cậy.

Chân dung · Loren Kohnfelder

Loren Kohnfelder hoàn thành luận văn cử nhân tại MIT vào tháng 5/1978 dưới sự hướng dẫn của Giáo sư Leonard Adleman (chữ 'A' trong RSA). Bản luận văn mang tên *"Towards a Practical Public-Key Cryptosystem"* lần đầu tiên trong lịch sử nhân loại định nghĩa cấu trúc của một chứng chỉ số được ký bởi một nhà cầm quyền trung ương (Central Authority / CA). Cấu trúc mà Kohnfelder phác thảo năm 1978 chính là tiền thân trực tiếp của chuẩn quốc tế ITU-T X.509 thống trị toàn bộ Internet ngày nay.

1.3 Hệ Mật RSA & Tối Ưu Hóa RSA-CRT

Quy trình sinh khóa RSA:

1. Chọn ngẫu nhiên hai số nguyên tố rất lớn p, q ($p \neq q$, thường có độ dài 1024-bit hoặc 2048-bit).
2. Tính $n = p \cdot q$ và $\phi(n) = (p-1)(q-1)$.
3. Chọn số mũ công khai e thỏa mãn $\gcd(e, \phi(n)) = 1$ (tiêu chuẩn quốc tế ấn định $e = 65537 = 2^{16} + 1$).
4. Tính số mũ bí mật $d \equiv e^{-1} \pmod{\phi(n)}$ bằng thuật toán Euclid mở rộng.

Kỹ thuật tăng tốc RSA-CRT: Thay vì tính $S = M^d \pmod{n}$ trực tiếp, ta tính trên hai nửa modulo p và q:

$$S_p = M^{d \pmod{p-1}} \pmod{p} \tag{1.4}$$
$$S_q = M^{d \pmod{q-1}} \pmod{q} \tag{1.5}$$
$$h = q^{-1} \cdot (S_p - S_q) \pmod{p} \tag{1.6}$$
$$S = S_q + h \cdot q \tag{1.7}$$

Kỹ thuật này giúp giảm độ phức tạp tính toán và tăng tốc độ ký số thực tế lên **4 lần**.

1.4 Mật Mã Đường Cong Elliptic (ECC)

Đường cong Elliptic trên trường hữu hạn $\mathbb{F}_p$ ($p > 3$) dạng rút gọn Weierstrass:

$$E : y^2 = x^3 + a \cdot x + b \pmod{p} \quad \text{với } 4a^3 + 27b^2 \not\equiv 0 \pmod{p} \tag{1.8}$$

Tập hợp các điểm $(x, y) \in \mathbb{F}_p \times \mathbb{F}_p$ thỏa mãn phương trình cùng với điểm vô cực $\mathcal{O}$ tạo thành một nhóm Abel hữu hạn dưới phép cộng điểm hình học (Chord-and-Tangent).

Mức An Toàn	Khóa Đối Xứng	Khóa RSA	Khóa ECC	Tỉ Lệ Tiết Kiệm
112-bit	3TDEA	2048 bits	224 bits	9.1 : 1
128-bit (Chuẩn hiện đại)	**AES-128**	**3072 bits**	**256 bits**	**12.0 : 1**
192-bit (An ninh cao)	**AES-192**	**7680 bits**	**384 bits**	**20.0 : 1**
256-bit (Tuyệt mật)	**AES-256**	**15360 bits**	**521 bits**	**29.5 : 1**

Bảng 1.1. Đối chiếu mức độ an toàn theo tiêu chuẩn NIST SP 800-57 Part 1 Rev 5.

Thực hành ngay

Sinh cặp khóa ECC Ed25519 hiện đại siêu nhanh bằng OpenSSL 3.5:

```
# Sinh khoa bi mat Ed25519
openssl genpkey -algorithm ED25519 -out ed25519.key
# Trich xuat khoa cong khai tuong ung
openssl pkey -in ed25519.key -pubout -out ed25519.pub
# In chi tiet thong so khoa
openssl pkey -in ed25519.key -text -noout
```

Thử thách trắc nghiệm

Cạm bẫy tấn công Bleichenbacher's Oracle trên RSA PKCS#1 v1.5: Trong giao thức TLS cũ sử dụng RSA trao đổi khóa, nếu máy chủ trả về các thông điệp lỗi khác nhau khi giải mã đệm PKCS#1 v1.5 sai, kẻ tấn công có thể gửi hàng nghìn truy vấn thích nghi để giải mã toàn bộ thông điệp mà không cần khóa bí mật. Tiêu chuẩn RFC 5246 và TLS 1.3 đã loại bỏ hoàn toàn cơ chế RSA key exchange và chuyển sang Ephemeral Diffie-Hellman (ECDHE).

Bài toán mở. Năm 1994, Peter Shor công bố thuật toán lượng tử chứng minh rằng cả bài toán phân tích thừa số nguyên tố (nền tảng RSA) và logarit rời rạc (nền tảng DH/ECC) đều bị giải quyết hoàn toàn trong thời gian đa thức $\mathcal{O}((\log N)^3)$. Khi máy tính lượng tử quy mô lớn (CRQC) ra đời, toàn bộ hệ mật RSA và ECC sẽ sụp đổ. Đây là động lực của cuộc đại di chuyển sang Mật mã Hậu lượng tử (PQC).

Tự kiểm tra

1. Tại sao thuật toán Euclid mở rộng lại đóng vai trò sống còn trong việc sinh khóa bí mật của hệ mật RSA?
2. Phân tích nguyên nhân vì sao khóa ECC kích thước 256-bit có thể cung cấp độ an toàn tương đương khóa RSA 3072-bit?
3. Nếu kẻ tấn công sở hữu máy tính lượng tử có khả năng chạy thuật toán Shor, thuật toán mã hóa đối xứng AES-256 có bị bẻ gãy hoàn toàn như RSA hay không? Giải thích.

Kết quả cần ghi nhớ

Toán học mật mã tạo ra các cặp khóa nhưng bất lực trước tấn công mạo danh (MitM). Hạ tầng khóa công khai (PKI) là hệ thống kỹ thuật và thể chế bắt buộc để ràng buộc khóa công khai với định danh pháp lý (Identity Binding). Kỹ thuật RSA-CRT tăng tốc

> xử lý ký số lên 4 lần. ECC vượt trội RSA về hiệu năng và kích thước khóa ở mức an toàn 128-bit trở lên.

Trang này được cố tình để trống.

2

Cấu Trúc Dữ Liệu Chứng Chỉ X.509 v3 & Quy Cách Mã Hóa ASN.1 DER

Bạn đang ở đâu: Cú pháp trừu tượng ASN.1 → Mã hóa nhị phân DER (TLV) → Khung dữ liệu TBSCertificate → Các phần mở rộng v3 trọng yếu → Quy định CA/B Forum

2.1 Cú Pháp ASN.1 & Quy Tắc Mã Hóa Nhị Phân DER

Chứng chỉ số không phải là một chuỗi văn bản thuần túy mà là một cấu trúc dữ liệu phân cấp được định nghĩa bằng chuẩn quốc tế **ASN.1 (Abstract Syntax Notation One – ITU-T X.680)** và được đóng gói nhị phân theo quy tắc **DER (Distinguished Encoding Rules – ITU-T X.690)**.

2.1.1 Cấu Trúc Khung Nhị Phân TLV (Tag – Length – Value)

Trong mã hóa DER, mọi thành phần dữ liệu đều được biểu diễn dưới dạng bộ ba:

1. **Tag (Thẻ phân loại):** 1 byte (hoặc nhiều bytes) xác định kiểu dữ liệu. Ví dụ: `0x02` (INTEGER), `0x03` (BIT STRING), `0x04` (OCTET STRING), `0x05` (NULL), `0x06` (OBJECT IDENTIFIER – OID), `0x30` (SEQUENCE).
2. **Length (Độ dài nội dung):** Số lượng bytes của phần Value. Nếu độ dài < 128, biểu diễn bằng 1 byte dạng ngắn (`0x00` – `0x7F`). Nếu độ dài ≥ 128, byte đầu có bit cao nhất bằng 1, các bit còn lại chỉ số lượng byte tiếp theo dùng để ghi độ dài.
3. **Value (Giá trị dữ liệu):** Chuỗi byte dữ liệu nhị phân thực tế của trường.

> **Nhìn vào bản chất**
>
> Tại sao PKI bắt buộc dùng mã hóa DER mà không dùng BER (Basic Encoding Rules)? BER cho phép nhiều cách biểu diễn nhị phân cho cùng một giá trị toán học (ví dụ: cờ boolean có thể biểu diễn bằng bất kỳ byte nào khác 0). Ngược lại, DER là chuẩn **đơn nhất tuyệt đối (Canonical Encoding)**: một cấu trúc ASN.1 chỉ có duy nhất một chuỗi byte nhị phân tương ứng. Nếu không dùng DER, kẻ tấn công có thể thay đổi cách mã hóa byte mà vẫn giữ nguyên ngữ nghĩa, dẫn đến việc chữ ký số bị sai lệch hoặc mở đường cho tấn công biến dạng chữ ký (*Signature Malleability*).

2.2 Cấu Trúc Khung Nhị Phân RFC 5280

Một chứng chỉ X.509 v3 chuẩn hóa theo IETF RFC 5280 bao gồm 3 khối dữ liệu chính:

1. **TBSCertificate (To-Be-Signed Certificate):** Toàn bộ nội dung thông tin chứng chỉ cần được CA ký xác thực.
2. **SignatureAlgorithm:** Định danh thuật toán mật mã mà CA sử dụng để ký (OID: ví dụ `sha256WithRSAEncryption` hoặc `ecdsa-with-SHA256`).
3. **SignatureValue:** Chữ ký số nhị phân được tính bằng cách băm toàn bộ khối nhị phân DER của TBSCertificate và ký bằng khóa bí mật của CA:

$$\sigma_{\text{CA}} = \text{Sign}(K_{\text{priv_CA}}, \text{Hash}(\text{TBSCertificate}_{\text{DER}})) \tag{2.1}$$

Trường Dữ Liệu	Kiểu ASN.1	Ý Nghĩa Kỹ Thuật
`version`	`EXPLICIT Version`	Phiên bản X.509 (v3 biểu diễn bằng số nguyên `0x02`)
`serialNumber`	`CertificateSerialNumber`	Số định danh duy nhất (ngẫu nhiên dương, tối đa 20 bytes)
`signature`	`AlgorithmIdentifier`	Thuật toán CA dùng để ký TBSCertificate
`issuer`	`Name`	Tên phân biệt (Distinguished Name – DN) của CA phát hành
`validity`	`Validity`	Thời gian hiệu lực (`notBefore` đến `notAfter`)
`subject`	`Name`	Tên phân biệt của thực thể được cấp chứng chỉ
`subjectPublicKeyInfo`	`SubjectPublicKeyInfo`	Khóa công khai của chủ thể và thuật toán tương ứng
`extensions`	`Extensions OPTIONAL`	Danh sách các phần mở rộng v3

Bảng 2.1. Cấu trúc các trường trong TBSCertificate theo RFC 5280.

2.3 Các Phần Mở Rộng Trọng Yếu (Critical Extensions)

Chuẩn X.509 v3 bổ sung cơ chế mở rộng linh hoạt. Mỗi phần mở rộng gồm một OID, cờ `critical` (BOOLEAN) và giá trị `extnValue` (OCTET STRING).

Định nghĩa 2.1 *(Quy tắc xử lý cờ Critical).* Nếu một phần mở rộng được đánh dấu `critical = TRUE`, mọi ứng dụng phần mềm thẩm tra (trình duyệt, hệ điều hành) **bắt buộc phải nhận biết và thực thi đúng ngữ nghĩa** của phần mở rộng đó. Nếu ứng dụng không hiểu phần mở rộng này, nó **bắt buộc phải từ chối chứng chỉ ngay lập tức**! □

Các phần mở rộng then chốt:

- **Basic Constraints (OID 2.5.29.19):** Bắt buộc đánh dấu `critical = TRUE` trên chứng chỉ CA. Chứa trường `cA = TRUE/FALSE` và ràng buộc độ sâu chuỗi `pathLenConstraint`.

- **Key Usage (OID 2.5.29.15):** Ràng buộc mục đích sử dụng của khóa công khai: `digitalSignature`, `keyCertSign`, `cRLSign`, `keyEncipherment`.
- **Extended Key Usage (OID 2.5.29.37):** Xác định ứng dụng cụ thể: `serverAuth` (TLS Web Server), `clientAuth` (mTLS), `codeSigning` (ký mã nguồn), `emailProtection` (S/MIME).
- **Subject Alternative Name – SAN (OID 2.5.29.17):** Danh sách tên miền (`dNSName`), địa chỉ IP (`iPAddress`), URI định danh cho chủ thể.

Ghi chú lịch sử

Trước năm 2017, các quản trị viên thường đặt tên miền máy chủ vào trường `Common Name (CN)` thuộc Subject DN (ví dụ: `CN=www.kma.edu.vn`). Tuy nhiên, trường CN chỉ chứa được một tên miền duy nhất, dễ gây nhầm lẫn cú pháp và không hỗ trợ nhiều dịch vụ hiện đại. Tháng 5/2017, Google Chrome 58 chính thức loại bỏ hoàn toàn việc kiểm tra CN, buộc mọi chứng chỉ Web PKI phải dùng trường SAN.

Thử thách trắc nghiệm

Cạm bẫy bỏ quên SAN: Nếu kỹ sư bảo mật sinh chứng chỉ web chỉ cấu hình trường Common Name (CN) mà bỏ qua phần mở rộng Subject Alternative Name (SAN), toàn bộ các trình duyệt hiện đại (Chrome, Safari, Edge, Firefox) sẽ chặn kết nối và hiển thị lỗi an ninh nghiêm trọng:

NET::ERR_CERT_COMMON_NAME_INVALID

Thực hành ngay

Giải mã nhị phân cấu trúc ASN.1 DER của một chứng chỉ bằng OpenSSL:

```
# Phan tich cau truc TLV cua file chung chi DER
openssl asn1parse -in cert.der -inform DER -i
# Trich xuat rieng phan mo rong Extensions
openssl x509 -in cert.pem -noout -text -certopt no_sigdump,no_pubkey
```

Tự kiểm tra

1. Điều gì xảy ra nếu chứng chỉ của một Intermediate CA bị quên thiết lập cờ `critical = TRUE` trên phần mở rộng Basic Constraints?
2. Tại sao một chứng chỉ máy chủ web TLS bắt buộc phải có phần mở rộng Extended Key Usage chứa mục đích `serverAuth`?
3. Phân biệt sự khác nhau giữa `digitalSignature` và `keyCertSign` trong phần mở rộng Key Usage.

Kết quả cần ghi nhớ

Mã hóa nhị phân DER bảo đảm tính đơn nhất tuyệt đối của chứng chỉ X.509, chống tấn công Signature Malleability. Cờ Critical buộc ứng dụng phải tuân thủ nghiêm ngặt chính sách an ninh. Toàn bộ hạ tầng Web PKI hiện đại đã bãi bỏ trường Common Name

> (CN) và bắt buộc sử dụng Subject Alternative Name (SAN).

3

Kiến Trúc Phân Tầng CA, Vòng Đời Khóa & Quy Chế CP/CPS (RFC 3647)

Bạn đang ở đâu: Mô hình 3 tầng (Root → Intermediate → End-Entity) → Khung quy chế CP/CPS RFC 3647 → Lễ sinh khóa Key Ceremony → Thiết bị HSM FIPS 140-3 → Vòng đời chứng chỉ

3.1 Kiến Trúc Chuỗi Tin Cậy Phân Tầng (3-Tier CA Hierarchy)

Hạ tầng PKI doanh nghiệp không bao giờ sử dụng một CA duy nhất để vừa đóng vai trò điểm tựa lòng tin tối cao vừa trực tiếp ký cấp phát chứng chỉ cho người dùng cuối. Thay vào đó, kiến trúc chuẩn hóa quốc tế thiết lập mô hình phân tầng tối thiểu 3 cấp:

1. **Root CA (Offline / Air-Gapped):** Đỉnh tháp tin cậy tối cao. Khóa bí mật của Root CA chỉ dùng để ký chứng chỉ tự ký (Self-signed) cho chính nó và ký chứng chỉ ủy quyền cho 1–2 Intermediate CA. Toàn bộ máy chủ Root CA được ngắt mạng vật lý (Air-gapped), tắt nguồn và niêm phong trong két sắt phòng sạch an ninh cao. Thời hạn hiệu lực: 15–25 năm.

2. **Issuing Intermediate CA (Online):** Nằm trong phân vùng mạng an ninh (DMZ/VPC), trực tiếp kết nối với các hệ thống tự động hóa (ACME RFC 8555, SCEP, EST) để cấp phát chứng chỉ hàng ngày cho máy chủ, ứng dụng và người dùng. Ràng buộc an ninh: `pathLenConstraint = 0`. Thời hạn hiệu lực: 3–5 năm.

3. **End-Entity Certificates (Lá cây – Leaf):** Chứng chỉ cấp cho máy chủ web, thiết bị IoT, lập trình viên phần mềm hoặc cán bộ nhân viên. Tuyệt đối không có quyền phát hành chứng chỉ khác (`isCA = FALSE`). Thời hạn hiệu lực: 90 ngày (hoặc tối đa 398 ngày).

> **Nhìn vào bản chất**
>
> Tại sao phải tốn kém chi phí duy trì mô hình phân tầng?
> Nếu một Root CA duy nhất trực tuyến cấp phát chứng chỉ hàng ngày và bị kẻ tấn công thỏa hiệp, **toàn bộ hệ sinh thái sẽ sụp đổ**. Việc thu hồi Root CA đòi hỏi phải cập nhật thủ công hàng triệu thiết bị, trình duyệt và hệ điều hành trên toàn cầu. Với kiến trúc phân tầng, nếu Intermediate CA bị lộ khóa, Root CA (đang nằm an toàn offline) chỉ cần khởi động trong 10 phút để ký một bản thu hồi CRL hủy bỏ Intermediate CA

đó và cấp ra Intermediate CA mới thay thế. Hệ thống người dùng không cần thay đổi Root Certificate.

3.2 Khung Quy Chế CP và CPS Theo Chuẩn IETF RFC 3647

Một hệ thống PKI hợp pháp bắt buộc phải có hai văn bản pháp lý và kỹ thuật cốt lõi:

- **Certificate Policy (CP – Chính sách Chứng chỉ):** Tuyên ngôn nguyên tắc cấp cao quy định đối tượng được cấp, mức độ tin cậy và trách nhiệm pháp lý.
- **Certification Practice Statement (CPS – Quy chế Thực hành):** Tài liệu kỹ thuật chi tiết mô tả chính xác cách thức CA vận hành để đáp ứng các yêu cầu nêu trong CP.

IETF RFC 3647 chuẩn hóa cấu trúc của CP/CPS thành **9 phần bắt buộc**:

1. Giới thiệu chung và phạm vi áp dụng (Introduction).
2. Trách nhiệm công bố và kho lưu trữ thông tin (Publication & Repository).
3. Quy trình định danh và xác thực danh tính (Identification & Authentication).
4. Yêu cầu nghiệp vụ vòng đời chứng chỉ (Certificate Life-Cycle Operations).
5. Kiểm soát an ninh cơ sở vật chất, quản trị và nhân sự (Facility, Management, and Operational Controls).
6. Kiểm soát an ninh kỹ thuật và mật mã (Technical Security Controls).
7. Cấu trúc chứng chỉ, CRL và hồ sơ OCSP (Certificate, CRL, and OCSP Profiles).
8. Đánh giá tuân thủ và kiểm toán độc lập (Compliance Audit and Other Assessments).
9. Các điều khoản pháp lý và kinh doanh (Other Business and Legal Matters).

3.3 Nghi Thức Lễ Sinh Khóa (Key Ceremony) & Chuẩn HSM

Khóa bí mật của Root CA là tài sản an ninh tối cao. Nó được tạo ra trong một nghi thức pháp lý và kỹ thuật đặc biệt gọi là **Lễ sinh khóa (Key Ceremony)**:

- **Không gian cách ly:** Phòng Faraday ngắt tuyệt đối mọi kết nối vô tuyến, điện thoại và thiết bị ghi âm; có sự chứng kiến của kiểm toán viên độc lập và máy quay an ninh đa góc 24/7.
- **Kiểm soát kép (Dual Control / M-of-N):** Khóa quản trị HSM được phân rã cho N người nắm giữ thẻ thông minh (Key Custodians) độc lập theo thuật toán chia sẻ bí mật Shamir. Cần sự có mặt đồng thời của tối thiểu M người ($M \leq N$, ví dụ 3-trong-5) để kích hoạt HSM.
- **Thiết bị phần cứng HSM (Hardware Security Module):** Đạt tiêu chuẩn an ninh **NIST FIPS 140-2 / FIPS 140-3 Level 3 hoặc Level 4**. Khóa được sinh bằng bộ tạo số ngẫu nhiên vật lý (Hardware TRNG). HSM có cảm biến vật lý tự hủy khóa ngay lập tức (*Zeroization*) nếu phát hiện hành vi cạy nắp, thay đổi nhiệt độ hoặc khoan phá mạch vi xử lý.

Thử thách trắc nghiệm

Thảm họa mất bản sao lưu HSM: Nếu CA không thực hiện quy trình sao lưu khóa Root CA sang các thẻ thông minh dự phòng (Backup Smartcards) theo cơ chế M-of-N, khi bo mạch phần cứng HSM gặp sự cố sốc điện hoặc hỏng chip, khóa bí mật của Root CA sẽ vĩnh viễn biến mất không thể phục hồi. Doanh nghiệp sẽ phải tuyên bố phá sản hạ tầng PKI và phát hành lại từ đầu toàn bộ hệ thống chứng chỉ!

Thực hành ngay

Tạo cấu hình phân tầng và sinh khóa Root CA bằng OpenSSL:

```
# Sinh khoa Root CA RSA-4096 ma hoa bang AES-256
openssl genpkey -algorithm RSA -pkeyopt rsa_keygen_bits:4096 \
  -aes256 -out root-ca.key
# Sinh chung chi tu ky Root CA thoi han 20 nam
openssl req -x509 -new -nodes -key root-ca.key -sha256 -days 7300 \
  -out root-ca.crt -subj "/CN=KMA National Root CA/O=KMA/C=VN" \
  -addext "basicConstraints=critical,CA:TRUE" \
  -addext "keyUsage=critical,keyCertSign,cRLSign"
```

Tự kiểm tra

1. Vì sao giá trị `pathLenConstraint = 0` trên Intermediate CA lại là một chốt chặn an ninh tối quan trọng?
2. Phân tích vai trò của kiểm toán viên độc lập (Independent Auditor) trong Lễ sinh khóa Root CA.
3. So sánh mức độ an ninh giữa HSM FIPS 140-3 Level 2 và Level 4.

Kết quả cần ghi nhớ

Mô hình phân tầng 3 cấp bảo vệ điểm tựa lòng tin tối cao trước các nguy cơ mạng. Tài liệu CP/CPS theo RFC 3647 là khuôn khổ pháp lý và quy chuẩn kỹ thuật bắt buộc của mọi CA. Thiết bị phần cứng HSM FIPS 140-3 kết hợp cơ chế kiểm soát kép M-of-N triệt tiêu hoàn toàn rủi ro nội bộ và rò rỉ khóa bí mật.

Trang này được cố tình để trống.

4

Thuật Toán Xác Thực Đường Dẫn Tin Cậy & Cơ Chế Thu Hồi Chứng Chỉ

Bạn đang ở đâu: Duyệt chuỗi tin cậy → 6 bước Path Validation RFC 5280 → Danh sách thu hồi CRL → Giao thức trực tuyến OCSP → Tối ưu hóa OCSP Stapling

4.1 Thuật Toán Thẩm Định Đường Dẫn (Path Validation Algorithm)

Khi một ứng dụng (trình duyệt web, ứng dụng ngân hàng) nhận được chứng chỉ từ máy chủ dịch vụ, nó không thể chấp nhận ngay lập tức mà phải xây dựng và thẩm tra toàn bộ chuỗi chứng chỉ ngược về Root CA nằm trong kho tin cậy (*Trust Store*):

$$C_{\text{Leaf}} \rightarrow C_{\text{Intermediate}} \rightarrow C_{\text{Root}} \tag{4.1}$$

Theo IETF RFC 5280 mục 6, thuật toán thẩm định đường dẫn thực hiện **6 bước kiểm tra nghiêm ngặt**:

1. **Xác minh chữ ký số (Signature Verification):** Khóa công khai của chứng chỉ cha C_{i+1} phải giải mã và xác nhận hợp lệ chữ ký số trên chứng chỉ con C_i.
2. **Kiểm tra thời gian hiệu lực (Validity Window):** Thời điểm kiểm tra hiện tại T_{current} phải nằm trọn vẹn trong khoảng $[\text{notBefore}, \text{notAfter}]$ của từng chứng chỉ trong chuỗi.
3. **Khớp nối tên định danh (Name Chaining):** Tên tổ chức phát hành của chứng chỉ con phải trùng khớp từng ký tự với tên chủ thể của chứng chỉ cha:

$$C_i.\text{Issuer} \equiv C_{i+1}.\text{Subject} \tag{4.2}$$

4. **Quyền hạn chứng thực CA:** Mọi chứng chỉ trung gian trên đường dẫn bắt buộc phải có phần mở rộng `basicConstraints.isCA = TRUE`.
5. **Độ sâu chuỗi (Path Length Constraint):** Số lượng cấp CA trung gian tính từ Root CA đến chứng chỉ lá không được vượt quá giá trị `pathLenConstraint`.
6. **Kiểm tra trạng thái thu hồi (Revocation Status):** Không có bất kỳ chứng chỉ nào trong chuỗi nằm trong danh sách thu hồi (CRL) hoặc bị máy chủ OCSP thông báo trạng thái `REVOKED`.

4.2 Cơ Chế Thu Hồi Chứng Chỉ: CRL vs OCSP vs OCSP Stapling

Khi khóa bí mật của người dùng bị lộ, thông tin định danh thay đổi hoặc nhân viên rời doanh nghiệp, chứng chỉ bắt buộc phải bị thu hồi trước khi hết hạn.

Đặc Trưng	CRL (RFC 5280)	OCSP (RFC 6960)	OCSP Stapling (RFC 6066)
Phương thức truyền	File nhị phân tĩnh HTTP	Truy vấn nhị phân HTTP	Kẹp kèm trong TLS Handshake
Kích thước dữ liệu	Rất nặng (hàng MB)	Nhẹ (vài trăm bytes)	Không tốn thêm kết nối
Quyền riêng tư	Tốt (CA không biết)	Kém (CA biết lịch sử duyệt)	**Bảo mật tuyệt đối**
Độ trễ kết nối	Cao khi tải file	Tăng thêm 1 RTT	**0 RTT (Tức thì)**
Xử lý sự cố mạng	Soft-fail	Soft-fail (Dễ bị tấn công)	**Hard-fail** (khi có Must-Staple)

Bảng 4.1. So sánh toàn diện ba cơ chế kiểm tra thu hồi chứng chỉ.

Nhìn vào bản chất

Hiểm họa chết người của chế độ Soft-fail:
Do lo ngại máy chủ của CA bị nghẽn mạng làm gián đoạn trải nghiệm người dùng, hầu hết các trình duyệt web mặc định chuyển sang chế độ **Soft-fail**: nếu không kết nối được tới máy chủ OCSP, trình duyệt sẽ coi như chứng chỉ vẫn còn hợp lệ!
Hậu quả: Kẻ tấn công Man-in-the-Middle sở hữu một chứng chỉ đã bị thu hồi chỉ cần chủ động chặn các gói tin DNS/HTTP gửi đến máy chủ OCSP Responder của CA. Trình duyệt nạn nhân sẽ tự động bỏ qua bước kiểm tra thu hồi và kết nối an toàn với máy chủ giả mạo của hacker!

4.3 Kỹ Thuật OCSP Stapling & Chuẩn OCSP Must-Staple (RFC 7633)

Để khắc phục triệt để lỗ hổng Soft-fail và bảo vệ quyền riêng tư người dùng, công nghệ hiện đại áp dụng **OCSP Stapling**:

1. Định kỳ (mỗi vài giờ), chính máy chủ Web sẽ tự chủ động truy vấn máy chủ OCSP của CA để lấy một bản phản hồi OCSP có chữ ký số hợp lệ (*OCSP Response*).
2. Khi người dùng kết nối qua TLS Handshake, máy chủ kẹp thẳng bản phản hồi này vào thông điệp `CertificateStatus`.
3. Trình duyệt nhận được bằng chứng thu hồi trực tiếp từ phiên bắt tay mà không cần gửi bất kỳ gói tin nào ra Internet.
4. Kết hợp cờ mở rộng **OCSP Must-Staple (RFC 7633)** trong chứng chỉ: Buộc trình duyệt phải chuyển sang chế độ **Hard-fail** (chặn kết nối ngay lập tức) nếu máy chủ không gửi kèm bản OCSP Stapled hợp lệ.

Thực hành ngay

Kiểm tra OCSP Stapling của một website trực tiếp bằng lệnh OpenSSL:

```
openssl s_client -connect www.cloudflare.com:443 -status -tlsextdebug < /dev/
    null \
  | grep -A 17 "OCSP Response Data:"
```

Tự kiểm tra

1. Trình bày chi tiết 6 bước kiểm tra của thuật toán Path Validation theo RFC 5280.
2. Phân tích tại sao cơ chế OCSP truyền thống lại vi phạm nghiêm trọng quyền riêng tư của người duyệt web.
3. Làm thế nào cờ OCSP Must-Staple loại trừ hoàn toàn nguy cơ tấn công Man-in-the-Middle dựa trên lỗ hổng Soft-fail?

Kết quả cần ghi nhớ

Thuật toán Path Validation bảo đảm toàn bộ mắt xích từ End-entity đến Root CA đều hợp lệ về chữ ký, thời gian, tên định danh và quyền hạn. Kỹ thuật OCSP Stapling kết hợp cờ Must-Staple là chuẩn mực công nghiệp cao nhất, tối ưu 0 RTT độ trễ và triệt tiêu nguy cơ tấn công thu hồi Soft-fail.

Trang này được cố tình để trống.

5

Giao Thức Quản Trị Tự Động ACME (RFC 8555) & Hạ Tầng Zero Trust PKI

Bạn đang ở đâu: Kiến trúc Zero Trust → Vấn đề chứng chỉ ngắn hạn → Chuẩn tự động hóa ACME RFC 8555 → Thử thách HTTP-01 / DNS-01 → mTLS Service Mesh

5.1 Triết Lý Zero Trust & Thách Thức Quản Trị Chứng Chỉ Ngắn Hạn

Mô hình an ninh truyền thống xây dựng trên giả định ”vùng biên mạng tin cậy” (Perimeter Security) đã hoàn toàn phá sản. Kiến trúc an ninh hiện đại chuyển dịch sang nguyên lý **Zero Trust**: *”Không bao giờ tin tưởng, luôn luôn xác thực” (Never Trust, Always Verify)*.

Trong kiến trúc Zero Trust:

- Mọi giao tiếp giữa các microservices trong mạng nội bộ đều phải được mã hóa và xác thực hai chiều qua giao thức **Mutual TLS (mTLS)**.
- Thời hạn hiệu lực của chứng chỉ bị rút ngắn tối đa (từ vài ngày xuống còn vài giờ hoặc vài phút – *Ephemeral Certificates*) để giảm thiểu thiệt hại khi khóa bí mật bị rò rỉ.
- Với hàng triệu chứng chỉ ngắn hạn xoay vòng liên tục mỗi ngày, việc cấp phát thủ công bằng con người là bất khả thi, đòi hỏi hạ tầng tự động hóa tuyệt đối.

5.2 Giao Thức Quản Trị Tự Động ACME (IETF RFC 8555)

Giao thức **ACME (Automated Certificate Management Environment – RFC 8555)** được phát triển bởi nhóm Let’s Encrypt và chuẩn hóa bởi IETF nhằm tự động hóa hoàn toàn quy trình xác thực tên miền, sinh khóa, cấp phát và gia hạn chứng chỉ số mà không cần sự can thiệp của con người.

5.2.1 Vòng Đời Giao Thức ACME

1. **Khởi tạo tài khoản (Account Creation):** ACME Client sinh một cặp khóa định danh tài khoản và gửi yêu cầu đăng ký lên ACME Server.
2. **Tạo đơn đặt hàng (Order Submission):** Client gửi danh sách tên miền cần xin cấp chứng chỉ (SAN domains).

3. **Phát hành thử thách (Challenges):** Server trả về các yêu cầu thử thách chứng minh quyền sở hữu tên miền.
4. **Thực hiện thử thách (Challenge Fulfillment):** Client triển khai nội dung thử thách và thông báo cho Server thẩm định.
5. **Hoàn tất và cấp phát (Finalize & Certificate Issuance):** Client gửi file yêu cầu ký chứng chỉ (CSR). Server ký và trả về chuỗi chứng chỉ X.509 hoàn chỉnh.

5.2.2 Các Phương Thức Thử Thách Sở Hữu Tên Miền

- **HTTP-01 Challenge:** ACME Server yêu cầu Client đặt một file xác thực tại đường dẫn công khai:

  `http://<YOUR_DOMAIN>/.well-known/acme-challenge/<TOKEN>` (5.1)

  ACME Server sẽ gửi truy vấn HTTP GET tới URL trên để kiểm tra giá trị `Key Authorization`. Nhược điểm: Bắt buộc mở cổng 80 và không cấp được chứng chỉ Wildcard (`*.kma.edu.vn`).

- **DNS-01 Challenge:** ACME Server yêu cầu Client tạo một bản ghi TXT trên hệ thống máy chủ DNS:

  `_acme-challenge.<YOUR_DOMAIN>` IN TXT `"<DIGEST>"` (5.2)

  Ưu điểm: Hỗ trợ chứng chỉ Wildcard, không cần mở cổng dịch vụ web và hoạt động hoàn hảo trong mạng nội bộ cô lập.

- **TLS-ALPN-01 Challenge:** Xác thực thông qua đàm phán giao thức lớp ứng dụng TLS ALPN trên cổng 443 với định danh `acme-tls/1`.

> **Nhìn vào bản chất**
>
> Tự động hóa là bức tường phòng thủ an ninh mạnh nhất:
> Theo thống kê của CA/B Forum, hơn 80% các vụ gián đoạn dịch vụ liên quan đến PKI trong thập kỷ qua xuất phát từ lỗi con người: quên gia hạn chứng chỉ khiến website bị sập hoặc cấu hình sai các trường ASN.1. Việc triển khai ACME không chỉ cắt giảm 99% chi phí vận hành mà còn loại bỏ hoàn toàn yếu tố sai sót chủ quan của con người.

5.3 Kiến Trúc mTLS Service Mesh & Quản Trị Danh Tính Động

Trong môi trường điện toán đám mây và Kubernetes, hạ tầng PKI được nhúng sâu vào Service Mesh (Istio, Linkerd) kết hợp các chuẩn định danh mã nguồn mở:

- **SPIFFE (Secure Production Identity Framework for Everyone):** Chuẩn hóa chuỗi định danh tài nguyên (SPIFFE ID dạng URI: `spiffe://kma.edu.vn/ns/prod/sa/payment-service`).
- **SPIRE (SPIFFE Runtime Environment):** Tự động cấp phát chứng chỉ số X.509 SVID ngắn hạn (thời hạn 1 giờ) vào bộ nhớ tạm của container mà không lưu khóa bí mật xuống đĩa cứng.
- **Step-CA & HashiCorp Vault:** Đóng vai trò máy chủ Issuing CA nội bộ cấp phát hàng chục nghìn chứng chỉ mTLS mỗi phút với hiệu năng cao.

Thực hành ngay

Khởi động máy chủ ACME nội bộ Step-CA bằng Docker:

```
# Khoi dong Step-CA ho tro ACME protocol tren cong 9000
docker run -d --name step-ca -p 9000:9000 \
  -e "DOCKER_STEPCA_INIT_NAME=KMA Private PKI" \
  -e "DOCKER_STEPCA_INIT_DNS_NAMES=localhost,step-ca.kma.local" \
  smallstep/step-ca
```

Tự kiểm tra

1. Phân tích quy trình bắt tay xác thực hai chiều mTLS và so sánh với TLS một chiều truyền thống.
2. Tại sao phương thức thử thách HTTP-01 không thể sử dụng để cấp chứng chỉ số Wildcard?
3. Trình bày cơ chế hoạt động của chuẩn định danh SPIFFE/SPIRE trong kiến trúc Kubernetes.

Kết quả cần ghi nhớ

Kiến trúc Zero Trust đòi hỏi mã hóa mTLS toàn diện và chứng chỉ số thời hạn ngắn (Ephemeral). Giao thức ACME (RFC 8555) giải quyết triệt để bài toán mở rộng quy mô thông qua tự động hóa hoàn toàn các phương thức thử thách HTTP-01 và DNS-01.

Trang này được cố tình để trống.

6

Các Kịch Bản Tấn Công Hạ Tầng PKI & Chiến Lược Phòng Thủ Toàn Diện

Bạn đang ở đâu: Mô hình đe dọa → Thảm họa lịch sử (DigiNotar, Flame) → Ma trận tấn công AD CS (ESC1–ESC8) → Giám sát CT Logs → Kiểm định tự động ZLint

6.1 Tổng Quan Mô Hình Đe Dọa Trên Hạ Tầng PKI

Hạ tầng PKI đối mặt với ba lớp tấn công chính:

1. **Compromised / Rogue CA:** Kẻ tấn công thâm nhập máy chủ CA hoặc nhân viên nội bộ biến chất tự ý ký phát hành các chứng chỉ giả mạo cho các tên miền nhạy cảm (`google.com`, `microsoft.com`).

2. **Thuật toán mật mã bị bẻ gãy:** Khai thác va chạm hàm băm (MD5, SHA-1) để tạo ra hai chứng chỉ có cùng giá trị băm nhưng khác nội dung, giúp chuyển chữ ký hợp lệ sang chứng chỉ độc hại.

3. **Cấu hình sai lệch hệ thống (Misconfiguration):** Lỗ hổng trong các mẫu chứng chỉ doanh nghiệp (như Active Directory Certificate Services – AD CS) cho phép người dùng bình thường leo thang đặc quyền Domain Admin.

6.2 Các Bài Học Xương Máu Trong Lịch Sử PKI

6.2.1 Vụ Án DigiNotar (Hà Lan – 2011)

DigiNotar là một Root CA công cộng uy tín của Hà Lan. Tháng 7/2011, hacker đã thâm nhập vào mạng nội bộ của DigiNotar do hệ thống thiếu phân tách mạng và thiếu giám sát bảo mật. Kẻ tấn công đã phát hành hơn **531 chứng chỉ giả mạo**, bao gồm `*.google.com`, `*.torproject.org` và `*.mozilla.org`.
Hậu quả: Hơn 300.000 người dùng Internet tại Iran đã bị cơ quan tình báo nghe lén toàn bộ tài khoản Gmail và dịch vụ tìm kiếm qua tấn công Man-in-the-Middle. Khi vụ việc bị phát hiện, Google, Microsoft, Apple và Mozilla đã đồng loạt xóa sổ DigiNotar khỏi mọi Trust Store, dẫn đến việc công ty này tuyên bố phá sản chỉ sau vài tuần.

6.2.2 Vũ Khí Mạng Flame (2012)

Mã độc gián điệp không gian mạng Flame đã tạo ra một chứng chỉ số giả mạo mang danh nghĩa Microsoft Windows Update. Kẻ tấn công đã tính toán một **va chạm tiền ảnh chọn trước (Chosen-prefix Collision)** trên thuật toán băm yếu MD5 được Microsoft Terminal Server sử dụng. Kết quả là mã độc đã vượt qua cơ chế kiểm tra chữ ký số của hệ điều hành Windows và tự động cài đặt vào hàng nghìn máy tính công nghiệp tối mật ở Trung Đông.

> **Nhìn vào bản chất**
>
> Sự ra đời của Certificate Transparency (CT Logs):
> Vụ án DigiNotar chứng minh rằng hệ sinh thái PKI truyền thống hoàn toàn bị động: khi một CA bị thâm nhập và âm thầm phát hành chứng chỉ giả mạo, chủ sở hữu tên miền (như Google) không có cách nào biết được sự tồn tại của chứng chỉ đó!
> Để giải quyết bài toán này, năm 2013, Ben Laurie (Google) đã khởi xướng chuẩn **Certificate Transparency (RFC 6962)**: Mọi chứng chỉ số trước khi được trình duyệt tin cậy **bắt buộc phải được ghi vào các sổ cái công khai (CT Logs)** hoạt động dựa trên cấu trúc cây Merkle chỉ thêm (Append-only Merkle Tree). Nhờ CT Logs, bất kỳ chứng chỉ giả mạo nào xuất hiện trên mạng đều bị các công cụ giám sát phát hiện chỉ trong vài phút.

6.3 Ma Trận Tấn Công Active Directory Certificate Services (AD CS)

Nghiên cứu đột phá của Will Schroeder và Lee Christensen (SpecterOps 2021) đã chỉ ra các kỹ thuật tấn công leo thang đặc quyền nghiêm trọng trong mạng nội bộ doanh nghiệp thông qua dịch vụ AD CS:

- **Lỗ hổng ESC1 (Misconfigured Certificate Template):** Mẫu chứng chỉ cấp cờ `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` kết hợp với mục đích EKU `Client Authentication`. Kẻ tấn công với tài khoản người dùng bình thường có thể yêu cầu cấp chứng chỉ nhưng điền tên chủ thể là tài khoản quản trị tối cao `Domain Admin`, sau đó sử dụng kỹ thuật PKINIT Kerberos để chiếm đoạt toàn bộ Domain Controller.
- **Lỗ hổng ESC8 (NTLM Relay to AD CS Web Enrollment):** Cổng đăng ký chứng chỉ qua giao diện web (`/certsrv`) mặc định không bật xác thực ký số NTLM và không bật HTTPS bảo vệ kênh truyền. Kẻ tấn công kích hoạt tấn công chuyển tiếp NTLM Relay từ một máy tính trong mạng sang cổng web của CA để yêu cầu cấp chứng chỉ máy cho Domain Controller, chiếm quyền kiểm soát toàn mạng.

6.4 Kiểm Định Tự Động Tuân Thủ Bằng ZLint

ZLint là bộ công cụ mã nguồn mở viết bằng Golang, được cộng đồng CA/B Forum và các nhà phát triển trình duyệt (Apple, Google, Mozilla) sử dụng làm tiêu chuẩn vàng để kiểm tra tuân thủ:

- Tự động đối chiếu chứng chỉ với hơn 300 quy tắc chuẩn hóa (RFC 5280, CA/B Forum Baseline Requirements).
- Phát hiện tức thời các lỗi cú pháp ASN.1, sai lệch cờ Critical, thiếu trường SAN hoặc độ dài khóa không đạt chuẩn.

Thực hành ngay

Kiểm tra tính tuân thủ của chứng chỉ X.509 bằng ZLint:

```
# Cai dat zlint bang Go
go install github.com/zmap/zlint/v3/cmd/zlint@latest
# Kiem dinh file chung chi PEM
zlint -pretty cert.pem | jq '.[] | select(.result == "error")'
```

Tự kiểm tra

1. Phân tích nguyên nhân sâu xa dẫn đến sự sụp đổ của tổ chức chứng thực DigiNotar năm 2011.
2. Cấu trúc cây Merkle trong Certificate Transparency hoạt động như thế nào để chứng minh tính toàn vẹn của sổ cái CT Logs?
3. Trình bày các biện pháp kỹ thuật để phòng ngự triệt để trước lỗ hổng AD CS ESC1 và ESC8.

Kết quả cần ghi nhớ

Hạ tầng PKI là mục tiêu hàng đầu của các cuộc tấn công mạng cấp quốc gia. Certificate Transparency (RFC 6962) biến việc phát hành chứng chỉ thành tiến trình minh bạch toàn cầu. Công cụ kiểm định tự động ZLint và rà soát ma trận lỗ hổng AD CS ESC1–ESC8 là yêu cầu phòng thủ bắt buộc của mọi trung tâm SOC hiện đại.

Trang này được cố tình để trống.

7

Chuyển Dịch Hệ Thống Sang Mật Mã Hậu Lượng Tử (PQC Migration)

Bạn đang ở đâu: Điện toán lượng tử → Thuật toán Shor & Grover → Hiểm họa HNDL → Chuẩn NIST FIPS 203/204/205 → Thách thức phân mảnh MTU → Chứng chỉ kép Hybrid RFC 9673

7.1 Mối Đe Dọa Của Điện Toán Lượng Tử & Thuật Toán Shor

Sự phát triển đột phá của máy tính lượng tử quy mô lớn có khả năng sửa lỗi (Cryptanalytically Relevant Quantum Computer – CRQC) đe dọa xóa sổ toàn bộ nền tảng mật mã khóa công khai hiện đại:

- **Thuật toán Shor (1994):** Cho phép tìm chu kỳ của hàm số trên không gian Hilbert lượng tử, qua đó giải quyết bài toán phân tích thừa số nguyên tố (bẻ gãy RSA) và bài toán logarit rời rạc trên trường hữu hạn lẫn đường cong Elliptic (bẻ gãy DSA, ECDSA, Ed25519) trong độ phức tạp thời gian đa thức:

$$\mathcal{O}((\log N)^3) \tag{7.1}$$

  Một máy tính lượng tử với khoảng 4.000 qubits logic có thể giải mã khóa RSA-2048 chỉ trong vài giờ!

- **Thuật toán Grover (1996):** Tăng tốc độ tìm kiếm trên cơ sở dữ liệu không có cấu trúc từ $\mathcal{O}(N)$ lên $\mathcal{O}(\sqrt{N})$. Thuật toán này làm giảm một nửa độ dài khóa hiệu dụng của các hàm băm và thuật toán đối xứng (AES-128 chỉ còn tương đương 64-bit an ninh; AES-256 vẫn an toàn tuyệt đối với 128-bit an ninh lượng tử).

7.2 Hiểm Họa Thu Hoạch Trước, Giải Mã Sau (HNDL)

Nhiều nhà quản trị lầm tưởng rằng chuyển dịch PQC là câu chuyện của tương lai xa khi máy tính lượng tử thương mại xuất hiện. Đây là một sai lầm chết người!
Chiến lược tấn công **Harvest Now, Decrypt Later (HNDL – Thu hoạch trước, Giải mã sau)** đang được các tổ chức tình báo hàng đầu thế giới triển khai rầm rộ:

1. Thu thập và lưu trữ hàng terabytes lưu lượng mạng mã hóa TLS, thông tin liên lạc chính phủ, hồ sơ bệnh án và bí mật công nghệ ngay tại thời điểm hiện tại.

2. Khi máy tính lượng tử hoàn thiện trong 5–10 năm tới, kẻ tấn công sẽ nạp dữ liệu lịch sử này vào để giải mã toàn bộ.

3. Mọi thông tin có chu kỳ bảo mật kéo dài trên 10 năm (bí mật quốc phòng, dữ liệu định danh công dân) đều đang đứng trước nguy cơ bị phơi bày hoàn toàn!

7.3 Bộ Tiêu Chuẩn NIST PQC Chính Thức (Tháng 8/2024)

Sau cuộc thi chuẩn hóa quốc tế kéo dài 8 năm (2016–2024), ngày 13/8/2024, Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ (NIST) đã chính thức ban hành bộ ba tiêu chuẩn Mật mã Hậu lượng tử đầu tiên của nhân loại:

1. **NIST FIPS 203 (ML-KEM):** Cơ chế đóng gói khóa (Key Encapsulation Mechanism) dựa trên bài toán mạng lưới Module Learning With Errors (Module-LWE), kế thừa từ thuật toán Kyber. Sử dụng cho trao đổi khóa bảo vệ kênh truyền TLS 1.3.

2. **NIST FIPS 204 (ML-DSA):** Chuẩn chữ ký số mạng lưới Module-LWE, kế thừa từ thuật toán Dilithium. Đóng vai trò thay thế trực tiếp cho RSA và ECDSA trong chữ ký chứng chỉ X.509.

3. **NIST FIPS 205 (SLH-DSA):** Chuẩn chữ ký số dựa trên hàm băm phi trạng thái (Stateless Hash-based Digital Signature Algorithm), kế thừa từ SPHINCS+. Đóng vai trò là phương án dự phòng an toàn tuyệt đối nếu các bài toán mạng lưới bị toán học bẻ gãy.

Thuật Toán	Tiêu Chuẩn	Khóa Công Khai	Khóa Bí Mật	Chữ Ký / Ciphertext
RSA-3072	Cổ điển	384 bytes	384 bytes	384 bytes
ECDSA P-256	Cổ điển	64 bytes	32 bytes	64 bytes
Ed25519	Cổ điển	32 bytes	32 bytes	64 bytes
ML-KEM-768	**NIST FIPS 203**	1,184 bytes	2,400 bytes	1,088 bytes
ML-DSA-65	**NIST FIPS 204**	1,952 bytes	4,032 bytes	**3,309 bytes**
ML-DSA-87	**NIST FIPS 204**	2,592 bytes	4,896 bytes	**4,627 bytes**
SLH-DSA-128s	**NIST FIPS 205**	32 bytes	64 bytes	**7,856 bytes**

Bảng 7.1. So sánh kích thước dữ liệu mật mã cổ điển và tiêu chuẩn NIST PQC FIPS.

7.4 Thách Thức Kỹ Thuật: Phân Mảnh TCP MTU & Kiến Trúc Lai Hybrid

Nhìn vào bản chất

Tại sao chuyển dịch PQC trong PKI lại khó khăn gấp bội?
Chữ ký Ed25519 cổ điển chỉ dài đúng **64 bytes**. Chữ ký ML-DSA-65 dài tới **3,309 bytes** (gấp hơn 50 lần!). Trong khi đó, kích thước khung truyền mạng cực đại (Maximum Transmission Unit – MTU) của chuẩn Ethernet là 1500 bytes.
Hậu quả: Một chuỗi chứng chỉ X.509 gồm 3 cấp PQC sẽ có kích thước vượt quá 10 KB, làm phân mảnh gói tin IP thành 7–8 mảnh TCP trong phiên bắt tay TLS Handshake. Hiện tượng này dẫn tới tỉ lệ rớt gói tin cao trên mạng di động 4G/5G, tăng vọt độ trễ bắt tay mạng và gây tràn bộ nhớ đệm trên các vi điều khiển IoT công nghiệp.

Để bảo đảm tính tương thích ngược và an toàn đa tầng trong giai đoạn quá độ, chuẩn quốc tế **IETF RFC 9673** quy định kiến trúc **Chứng chỉ số lai kép (Hybrid X.509 Certificate)**:

$$\text{Certificate}_{\text{Hybrid}} = \{\text{Subject}, K_{\text{pub_Classic}}, K_{\text{pub_PQC}}\} + \sigma_{\text{Classic}} + \sigma_{\text{PQC}} \tag{7.2}$$

Kênh truyền chỉ được coi là tin cậy nếu **cả hai chữ ký cổ điển và PQC đều được thẩm định thành công**, loại trừ triệt để nguy cơ tấn công HNDL trong khi vẫn bảo đảm vận hành trơn tru trên các phần mềm cũ.

Thực hành ngay

Khởi tạo cặp khóa và chứng chỉ số PQC ML-DSA-65 bằng OpenSSL 3.5:

```
# Sinh khoa bi mat ML-DSA-65 (NIST FIPS 204)
openssl genpkey -algorithm mldsa65 -out mldsa65.key
# Sinh chung chi tu ky PQC Root CA
openssl req -x509 -new -key mldsa65.key -out mldsa65-root.crt \
  -days 3650 -subj "/CN=KMA Post-Quantum Root CA/O=KMA/C=VN"
# In chi tiet chung chi PQC
openssl x509 -in mldsa65-root.crt -text -noout
```

Tự kiểm tra

1. Phân tích cơ chế toán học của thuật toán Shor và giải thích vì sao nó có thể bẻ gãy RSA và ECC trong thời gian đa thức.
2. Thuật toán Grover ảnh hưởng như thế nào đến độ dài an toàn của thuật toán mã hóa đối xứng AES?
3. Trình bày các giải pháp kỹ thuật để xử lý hiện tượng phân mảnh gói tin TCP khi triển khai chứng chỉ PQC trên mạng viễn thông.

Kết quả cần ghi nhớ

Mối đe dọa HNDL đòi hỏi phải di chuyển PQC ngay hôm nay. NIST FIPS 203 (ML-KEM) và FIPS 204 (ML-DSA) là các chuẩn mực toàn cầu mới. Kích thước chữ ký PQC lớn gây phân mảnh MTU, đòi hỏi áp dụng kiến trúc chứng chỉ lai kép Hybrid X.509 (RFC 9673) trong giai đoạn chuyển tiếp.

Trang này được cố tình để trống.

8

Khung Pháp Lý, Quy Chuẩn Kỹ Thuật & Hạ Tầng Chữ Ký Số Quốc Gia

Bạn đang ở đâu: Hành lang pháp lý quốc gia → Luật Giao dịch điện tử 2023 → Quyết định 1875/QĐ-TTg → Mô hình Root CA Quốc gia → Chữ ký số từ xa (Remote Signing)

8.1 Hành Lang Pháp Lý: Luật Giao Dịch Điện Tử Năm 2023

Tại Việt Nam, hạ tầng khóa công khai được điều chỉnh bởi khung pháp lý cao nhất là **Luật Giao dịch điện tử năm 2023 (Luật số 20/2023/QH15)**, có hiệu lực thi hành từ ngày 01/07/2024:

- **Phân loại chữ ký điện tử (Điều 21):** Luật phân định rõ ba cấp độ chữ ký điện tử:
  1. Chữ ký điện tử chuyên dùng (dùng riêng cho cơ quan, tổ chức nội bộ).
  2. Chữ ký số chuyên dùng công vụ (phục vụ hoạt động của các cơ quan nhà nước, do Ban Cơ yếu Chính phủ quản trị).
  3. Chữ ký số công cộng (cung cấp dịch vụ cho người dân và doanh nghiệp số).
- **Giá trị pháp lý tương đương (Điều 23):** Chữ ký số an toàn đáp ứng đủ điều kiện theo quy định của pháp luật có **giá trị pháp lý tương đương chữ ký tay** của cá nhân trên văn bản giấy; chữ ký số của cơ quan, tổ chức có **giá trị tương đương con dấu pháp nhân**.
- **Nguyên tắc chống chối bỏ (Non-repudiation):** Khi một thông điệp dữ liệu đã được ký bằng chữ ký số hợp lệ, người ký không thể phủ nhận việc mình đã tạo lập hoặc đồng thuận với nội dung giao dịch đó.

8.2 Chiến Lược Quốc Gia Về Chuyển Dịch PQC Theo Quyết Định 1875/QĐ-TTg

Nhận thức rõ nguy cơ từ điện toán lượng tử đối với an ninh quốc gia, Thủ tướng Chính phủ đã ban hành **Quyết định số 1875/QĐ-TTg** phê duyệt Chiến lược phát triển ngành Cơ yếu Việt Nam:

- Xác định nhiệm vụ trọng tâm: Chủ động nghiên cứu, thử nghiệm và xây dựng lộ trình chuyển đổi toàn bộ hạ tầng mật mã khóa công khai quốc gia sang chuẩn Mật mã Hậu lượng tử (PQC).
- Ưu tiên bảo vệ các hệ thống thông tin phục vụ chỉ đạo, điều hành của Đảng, Nhà nước, lực lượng vũ trang và các cơ sở hạ tầng thông tin trọng yếu quốc gia (tài chính, ngân hàng, năng lượng).

8.3 Kiến Trúc Hạ Tầng Khóa Công Khai Quốc Gia

Mô hình PKI quốc gia của Việt Nam được cấu trúc thành hai nhánh song song độc lập dưới sự điều phối của Bộ Thông tin & Truyền thông và Ban Cơ yếu Chính phủ:

1. **Nhánh Dịch vụ Chứng thực Chữ ký số Công cộng:** Đỉnh tháp là **National Root CA** do Trung tâm Chứng thực điện tử quốc gia (NEAC) vận hành. National Root CA ký cấp chứng chỉ cho các nhà cung cấp dịch vụ chứng thực chữ ký số công cộng (Public CA: VNPT-CA, Viettel-CA, BKAV-CA, FPT-CA...). Các Public CA này sau đó cấp chứng chỉ cho công dân và doanh nghiệp.
2. **Nhánh Chữ ký số Chuyên dùng Công vụ:** Do Cục Chứng thực số và An toàn thông tin thuộc Ban Cơ yếu Chính phủ trực tiếp quản lý và vận hành, phục vụ riêng cho các cơ quan Đảng và Nhà nước từ Trung ương đến địa phương.

8.4 Công Nghệ Chữ Ký Số Từ Xa (Remote Signing / Cloud PKI)

Xu thế hiện đại chuyển dịch từ thiết bị lưu trữ vật lý USB Token sang công nghệ **Ký số từ xa (Remote Signing)**:

- Khóa bí mật của người dùng được lưu trữ và bảo vệ tập trung trong các thiết bị HSM chuyên dụng chuẩn **eIDAS (châu Âu) và Common Criteria EAL4+**.
- Người dùng thực hiện ký số trên điện thoại thông minh thông qua xác thực đa nhân tố (MFA / Sinh trắc học FIDO2).
- Đạt tốc độ ký hàng nghìn tài liệu mỗi giây, phục vụ đắc lực cho chương trình Chuyển đổi số Quốc gia.

Thực hành ngay

Kiểm tra thông tin chứng chỉ của Root CA Quốc gia Việt Nam:

```
# Tai va xem thong tin chung chi National Root CA tu website NEAC
curl -s http://neac.gov.vn/certificates/RootCA.cer | \
  openssl x509 -inform DER -text -noout | grep -E "Issuer|Subject|Validity"
```

Tự kiểm tra

1. Phân tích các điều kiện để một chữ ký số được công nhận có giá trị pháp lý tương đương chữ ký tay theo Luật Giao dịch điện tử 2023.
2. So sánh mô hình tổ chức của Nhánh Chữ ký số Công cộng (NEAC) và Nhánh

Chuyên dùng Công vụ (Ban Cơ yếu Chính phủ).

3. Công nghệ Ký số từ xa (Remote Signing) giải quyết bài toán trải nghiệm người dùng như thế nào trong khi vẫn bảo đảm tính an toàn của khóa bí mật?

Kết quả cần ghi nhớ

Luật Giao dịch điện tử năm 2023 là nền móng pháp lý vững chắc cho chữ ký số an toàn tại Việt Nam. Quyết định số 1875/QĐ-TTg đặt ra yêu cầu chiến lược cấp bách về chuyển dịch PQC. Kiến trúc PKI quốc gia phân tầng bảo đảm tính toàn vẹn và chủ quyền số quốc gia trên không gian mạng.

Trang này được cố tình để trống.

Cẩm Nang 50 Lệnh OpenSSL 3.5 Thực Chiến

.1 Quản Trị Khóa & Tham Số Mật Mã

```
# 1. Sinh khoa bi mat RSA 4096-bit co ma hoa AES-256
openssl genpkey -algorithm RSA -pkeyopt rsa_keygen_bits:4096 -aes256 -out rsa4096.
    key

# 2. Trich xuat khoa cong khai tu khoa bi mat RSA
openssl pkey -in rsa4096.key -pubout -out rsa4096.pub

# 3. Kiem tra tinh toan ven toan hoc cua khoa RSA
openssl rsa -in rsa4096.key -check -noout

# 4. Sinh khoa bi mat ECC P-256 (prime256v1)
openssl genpkey -algorithm EC -pkeyopt ec_paramgen_curve:P-256 -out ec256.key

# 5. Sinh khoa bi mat ECC Ed25519 sieu nhe
openssl genpkey -algorithm ED25519 -out ed25519.key

# 6. Sinh khoa bi mat Post-Quantum ML-DSA-65 (NIST FIPS 204)
openssl genpkey -algorithm mldsa65 -out mldsa65.key
```

.2 Yêu Cầu Ký Chứng Chỉ (CSR) & Cấu Hình SAN

```
# 7. Sinh CSR voi Subject Alternative Name (SAN) 1 dong lenh duy nhat
openssl req -new -key rsa4096.key -out srv.csr \
  -subj "/CN=kma.edu.vn/O=KMA/C=VN" \
  -addext "subjectAltName=DNS:kma.edu.vn,DNS:*.kma.edu.vn,IP:192.168.1.10"

# 8. Kiem tra noi dung va xac thuc chu ky ben trong file CSR
openssl req -in srv.csr -text -noout -verify
```

.3 Ký Phát Hành & Thẩm Tra Chuỗi X.509

```
# 9. Intermediate CA ky cap chung chi may chu thoi han 90 ngay
openssl x509 -req -in srv.csr -CA intermediate-ca.crt -CAkey intermediate-ca.key \
  -CAcreateserial -out srv.crt -days 90 -sha256 \
  -extfile <(echo -e "basicConstraints=critical,CA:FALSE\nkeyUsage=critical,
    digitalSignature,keyEncipherment\nextendedKeyUsage=serverAuth\nsubjectAltName=
    DNS:kma.edu.vn,DNS:*.kma.edu.vn")

```

```
# 10. Tham tra toan bo chuoi chung chi ve Root CA (Path Validation)
openssl verify -CAfile root-ca.crt -untrusted intermediate-ca.crt srv.crt
```

.4 Kiểm Tra Thu Hồi & Giao Thức OCSP

```
# 11. Khoi tao may chu OCSP Responder noi bo tren cong 8888
openssl ocsp -index index.txt -port 8888 -rsigner ocsp.crt -rkey ocsp.key \
  -CA intermediate-ca.crt -text

# 12. Gui truy van OCSP kiem tra trang thai thu hoi truc tiep
openssl ocsp -CAfile intermediate-ca.crt -issuer intermediate-ca.crt \
  -cert srv.crt -url http://127.0.0.1:8888
```

Bộ Công Cụ Python Cryptography Kiểm Định X.509

Listing 1. Script Python kiem tra va boc tach chi tiet cac truong X.509

```
from cryptography import x509
from cryptography.hazmat.backends import default_backend
from cryptography.x509.oid import ExtensionOID
import datetime

def audit_certificate(pem_path: str):
    with open(pem_path, "rb") as f:
        cert = x509.load_pem_x509_certificate(f.read(), default_backend())

    print(f"[*] Subject: {cert.subject.rfc4514_string()}")
    print(f"[*] Issuer:  {cert.issuer.rfc4514_string()}")
    print(f"[*] Serial:  {hex(cert.serial_number)}")
    print(f"[*] Validity: {cert.not_valid_before_utc} to {cert.not_valid_after_utc
    }")

    # Kiem tra thoi han
    now = datetime.datetime.now(datetime.timezone.utc)
    if not (cert.not_valid_before_utc <= now <= cert.not_valid_after_utc):
        print("[!] CANH BAO: Chung chi het han hoac chua co hieu luc!")

    # Kiem tra SAN
    try:
        san = cert.extensions.get_extension_for_oid(ExtensionOID.
    SUBJECT_ALTERNATIVE_NAME)
        dns_names = san.value.get_values_for_type(x509.DNSName)
        print(f"[+] SAN DNS: {dns_names}")
    except x509.ExtensionNotFound:
        print("[!] LOI NGHIEP VU: Chung chi thieu phan mo rong SAN!")

if __name__ == "__main__":
    audit_certificate("srv.crt")
```

Trang này được cố tình để trống.

Danh Mục Tài Liệu Tham Khảo Hàn Lâm & Video OCW Quốc Tế

.5 Tiêu Chuẩn Quốc Tế IETF RFC & CA/B Forum

1. IETF RFC 5280: *Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile*, May 2008.

2. IETF RFC 6960: *X.509 Internet Public Key Infrastructure Online Certificate Status Protocol – OCSP*, June 2013.

3. IETF RFC 6962: *Certificate Transparency*, June 2013.

4. IETF RFC 8555: *Automatic Certificate Management Environment (ACME)*, March 2019.

5. IETF RFC 9673: *Composite Public Keys and Signatures for Use in Internet PKI*, 2024.

6. CA/Browser Forum: *Baseline Requirements for the Issuance and Management of Publicly-Trusted Certificates*, v2.0.8, 2024.

.6 Tiêu Chuẩn Viện Tiêu Chuẩn & Công Nghệ Quốc Gia Hoa Kỳ (NIST)

1. NIST FIPS 203: *Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM)*, August 2024.

2. NIST FIPS 204: *Module-Lattice-Based Digital Signature Standard (ML-DSA)*, August 2024.

3. NIST FIPS 205: *Stateless Hash-Based Digital Signature Standard (SLH-DSA)*, August 2024.

4. NIST SP 800-57 Part 1 Rev. 5: *Recommendation for Key Management*, May 2020.

.7 Sách Chuyên Khảo Kinh Điển

1. Carlisle Adams and Steve Lloyd, *Understanding PKI: Concepts, Standards, and Deployment Considerations*, 2nd Edition, Addison-Wesley, 2003.

2. Christof Paar and Jan Pelzl, *Understanding Cryptography: A Textbook for Students and Practitioners*, Springer, 2010.

3. Ivan Ristić, *Bulletproof TLS and PKI*, 2nd Edition, Feisty Duck, 2022.

.8 Khóa Học Mở Quốc Tế (OpenCourseWare – OCW)

1. **Stanford University CS 255:** *Cryptography*, Prof. Dan Boneh. URL: `https://crypto.stanford.edu/~dabo/cs255/`
2. **MIT 6.857:** *Computer and Network Security*, Prof. Ronald L. Rivest. URL: `https://courses.csail.mit.edu/6.857/`
3. **Carnegie Mellon University 18-730:** *Introduction to Computer Security*, Prof. Virgil Gligor.
4. **University of Cambridge:** *Security and Cryptography Lecture Series*, Computer Laboratory.